

访问控制漏洞报告（Lab4：用户 ID 由请求参数控制 - IDOR 越权）

1. 漏洞名称

不安全的直接对象引用（IDOR / Insecure Direct Object Reference） — 水平越权

2. 漏洞等级

高危（High）

3. 漏洞描述

该网站的用户个人中心页面通过 URL 参数 id 来识别当前访问的用户（如 id=wiener）。后端在处理请求时，**缺乏对当前登录用户和目标 ID 的归属校验**。攻击者只需将自己的登录凭证换成普通用户，然后篡改 URL 中的 id 参数为其他合法用户名（如 carlos），即可利用他人身份查看并窃取敏感信息（如用户的 API 密钥）。

4. 漏洞位置

请求方式：GET /my-account

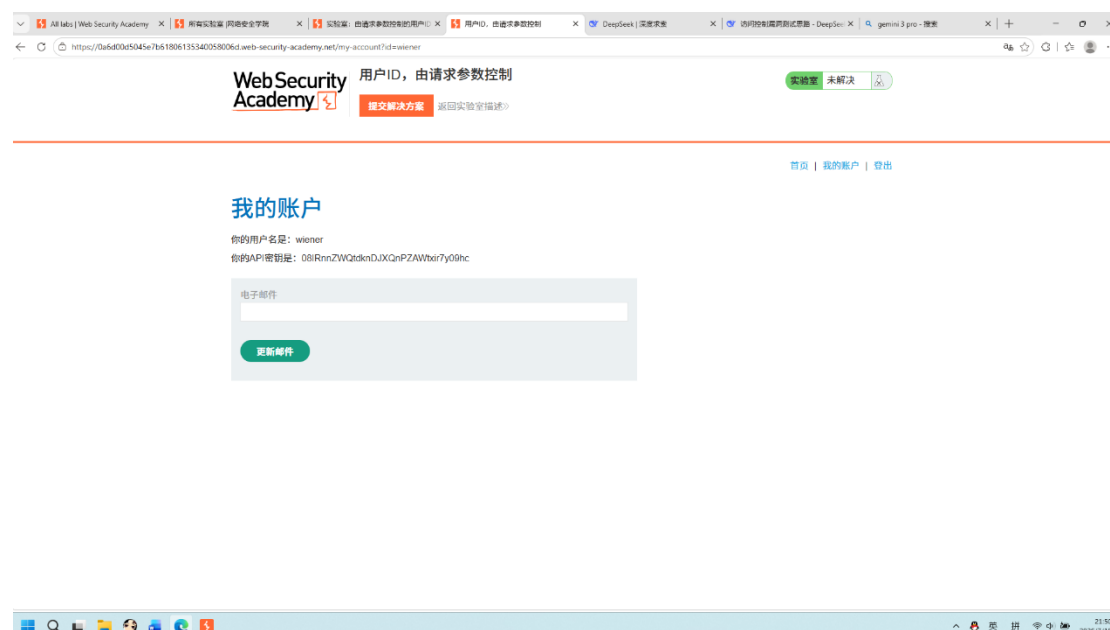
漏洞参数：id（URL 查询参数）

5. 漏洞复现过程

第一步：正常登录与信息收集

使用提供的测试账号 wiener:peter 进行登录，进入个人中心页面。

图 1：查看当前登录用户的 API 密钥



说明：登录成功，观察到 URL 参数为 id=wiener，并且页面展示了敏感信息 API 密

钥。

第二步：发现参数并实施越权尝试

观察浏览器地址栏，发现 /my-account 路径的请求是通过 id 参数控制展示内容的。将地址栏中的 id=wiener 手动修改为 id=carlos，并直接回车访问。

图 2：成功越权查看目标用户的 API 密钥



说明：在没有输入 Carlos 密码、未登出当前账号的情况下，仅仅修改 URL 参数，成功加载了 Carlos 的个人中心页面，并获取到了他的敏感 API 密钥。

第三步：获取目标密钥并提交验证

记录下 Carlos 的 API 密钥字符串，在实验页面上方的“提交解决方案”输入框中粘贴该密钥并提交。

图 3：成功解决实验



说明：漏洞利用成功，靶场确认已获取到 Carlos 的敏感凭证。

6. 漏洞原理

该漏洞属于水平越权（Horizontal Privilege Escalation）。

1. 后端在查询用户信息时，直接使用了前端 URL 传递的 id 参数作为 SQL 查询的 WHERE 条件（例如 `SELECT * FROM users WHERE id = 'carlos'`）。
2. **严重安全缺陷**：后端在执行该查询前，**没有校验** carlos 这个 ID 是否属于当前登录的 Session 用户（wiener）。
3. 攻击者只要知道其他用户的 ID（实验中为简单的用户名），就能直接访问他人的私密数据。

7. 漏洞影响

- **数据泄露**：攻击者可以遍历 ID，批量窃取系统内所有用户的个人敏感信息（如手机号、邮箱、API 密钥、余额等）。
- **隐私侵犯**：严重破坏用户个人数据的保密性。

8. 修复建议

- ① **强制服务端权限校验（关键）**：后端在接收 `id=carlos` 时，必须从当前请求的 Session / Token 中提取**当前登录者的 ID**。只有当 `Session.id == 请求参数.id` 时，才允许返回数据。
- ② **使用非连续/不可预测的 ID**：不应使用自增数字或公开的用户名作为参数，应使用 UUID 或经过加密签名的哈希值作为对象标识。
- ③ **采用基于 Session 的数据查询**：如果页面只能查询“自己”的信息，后端完全可以不

接收 id 参数，而是直接读取 Session 中存储的用户 ID 自动查询数据库。

9. 工具

- **Google Chrome / Firefox** (直接修改 URL 参数)
- **PortSwigger Web Security Academy** (靶场平台)